

COMPLIANCE OFFENSIVE ENGAGEMENT

Cybersecurity Capture-The-Flag Engagement Proposal

*A realistic, progressive, five-flag offensive-security exercise
in a fully isolated, controlled virtual environment*

Prepared for: Indian Army Central Command, Lucknow
Date: 07/09/2026

CONFIDENTIAL - Prepared exclusively for the recipient client. Not for redistribution.

Table of Contents

1. Executive Summary	3
2. CTF Objectives	3
3. Proposed Environment.....	3
4. Architecture.....	4
5. CTF Storyline.....	4
6. Complete Attack/Challenge Flow	5
7. Five-Flag Progression.....	5
8. Rabbit Holes.....	6
9. Hint/Riddle System.....	7
10. Skills Tested	7
11. Difficulty Progression.....	7
12. Participant Experience.....	8
13. Security/Isolation Considerations	8
14. Proposed Deliverables.....	9
15. Attacker Machines.....	9
16. Supplementary Practice Environments	9
16. Conclusion	10

1. Executive Summary

This proposal outlines a purpose-built cybersecurity Capture-The-Flag (CTF) exercise designed to give participants realistic, hands-on offensive-security practice in a fully controlled and isolated environment. The exercise is built around a believable intelligence/security-themed storyline rather than an obvious series of disconnected puzzles, so participants practice the same investigative mindset and methodology they would apply in a real engagement.

The engagement centers on a single target system containing five progressively difficult flags. Participants start with nothing but a target IP address and must apply reconnaissance, web analysis, steganography, credential handling, Linux enumeration, and controlled privilege escalation to reach full compromise. The environment is self-contained, safe to run repeatedly, and has no dependency on or access to production infrastructure.

2. CTF Objectives

- Provide hands-on practice spanning the full offensive engagement lifecycle: reconnaissance, initial access, lateral discovery, privilege escalation, and full compromise.
- Reinforce structured methodology, patience, and verification habits rather than rewarding guesswork.
- Present a believable, realistic scenario that keeps participants in an investigative mindset instead of an obvious “game” framing.
- Exercise a broad and representative skill set: network scanning, web enumeration, steganography, wordlist-based credential recovery, SSH usage, Linux permissions analysis, and basic reverse engineering.
- Deliver the exercise in a safe, isolated, and fully resettable environment suitable for repeated use across multiple sessions, teams, or cohorts.

3. Proposed Environment

The exercise is hosted entirely within a controlled Proxmox virtual environment, keeping every component - participant machines and the CTF target alike - isolated from the client's production systems.

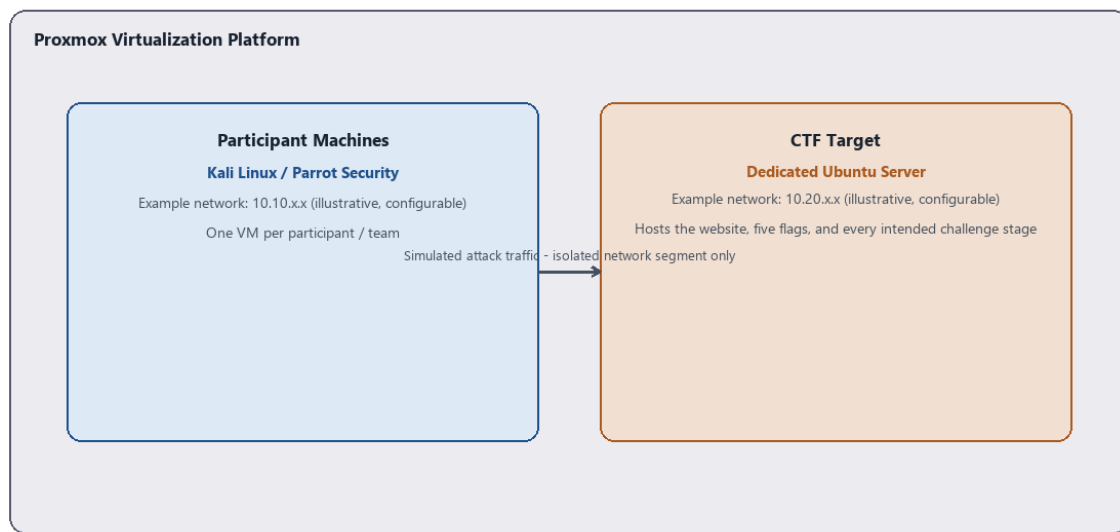
Component	Description
Hosting platform	Proxmox VE (virtualization) - dedicated to the exercise
Participant machine(s)	Kali Linux / Parrot Security attacker VMs, example network 10.10.x.x
CTF target and other vulnerable VMs	Dedicated Ubuntu Server VM hosting the exercise, example network 10.20.x.x
Network isolation	Dedicated virtual network segment with no route to production infrastructure

Both 10.10.x.x and 10.20.x.x above are illustrative examples only. Both ranges are fully configurable and will be adapted to fit the client's actual environment and addressing scheme.

4. Architecture

At a high level, participant machines and the CTF target both run as virtual machines under Proxmox, connected only through an isolated network segment dedicated to the exercise. No component of the exercise requires or is granted access to the client's production network, management interfaces, or other virtual machines.

Proposed Environment Architecture



10.10.x.x and 10.20.x.x are illustrative examples only - both ranges are fully configurable to match the client's environment.

Figure 1: Proposed environment architecture

5. CTF Storyline

The exercise is framed around a fictional intelligence/security consultancy whose public-facing website looks entirely ordinary at first glance. Nothing on the surface announces that this is a CTF - there is no obvious "start here" messaging, no flag placeholders, and no puzzle-like styling. Participants are expected to treat the target the way they would a real reconnaissance target: methodically, and without assuming anything is exactly as it appears.

As the engagement progresses, participants uncover a trail of operational history the organization never properly cleaned up: forgotten credentials, an old backup location, a second account with elevated access, and finally a narrowly-scoped, intentionally controlled path to full administrative control. The storyline exists

to keep participants oriented and motivated - it does not change the technical skills being tested, but it makes practicing them feel like a real investigation rather than an artificial exercise.

6. Complete Attack/Challenge Flow

The exercise follows a single, internally consistent path from initial reconnaissance through to full compromise. Each stage below is described at a conceptual level; no exact commands, file locations, or credentials are included in this document.

1. Participants receive only the CTF target's IP address and perform standard reconnaissance to identify running services.
2. Initial web reconnaissance uncovers the organization's website and, through standard enumeration, a restricted path referenced by the site's crawler-control file.
3. Following that path leads to a page that is not linked from normal navigation, where the first flag is present in an encoded form after reviewing the page's content.
4. Separately, an image published on the website is found to contain hidden data, recoverable through steganographic analysis once the correct passphrase is identified via a wordlist-based approach.
5. The recovered hidden data contains an encoded credential which, once decoded, grants SSH access to a first, intentionally low-privileged account.
6. Enumeration of that account's home directory reveals a second encoded flag and a directory not visible through a normal listing.
7. Clues within that hidden directory point toward an old backup location elsewhere on the system.
8. Investigating the backup location reveals a third encoded flag and a private key belonging to a second, more privileged account.
9. That key grants SSH access to the second account, which is deliberately more privileged than the first but is still not fully privileged.
10. Reviewing that account's command history reveals a fourth encoded flag.
11. Further investigation reveals a narrowly-scoped, intentionally controlled path that permits execution of one specific administrative utility - a custom binary - under tightly constrained conditions.
12. Participants transfer that utility off the target system and analyze it using reverse-engineering tooling (such as Ghidra) to recover a required value.
13. Supplying that recovered value through the permitted, controlled path results in full administrative access to the target system.
14. The fifth and final flag, also stored in encoded form, is located within the administrator's own area of the system once full access is achieved.

7. Five-Flag Progression

Each flag marks the successful completion of a distinct stage, with purpose, objective, and tested skill deliberately escalating as the exercise progresses.

Five-Flag Progression



Difficulty and required skill depth increase with each successive flag.

Figure 2: The five stages of the exercise

Flag	Stage	Purpose	Skill Tested
Flag 1	Web Reconnaissance	Establishes the reconnaissance mindset and rewards thorough web enumeration.	Web recon, crawler-control file analysis, encoding awareness
Flag 2	Initial Access	Rewards successful credential recovery and first authenticated foothold.	Steganography, wordlist-based recovery, SSH usage
Flag 3	Lateral Discovery	Encourages thorough host-level enumeration beyond the obvious.	Filesystem enumeration, permissions analysis, artifact discovery
Flag 4	Secondary Access	Rewards pivoting to a second, more privileged account.	Key-based SSH access, activity-history review
Flag 5	Full Compromise	Culminates the exercise via a deliberately controlled escalation path.	Reverse engineering, controlled privilege-escalation reasoning

8. Rabbit Holes

Three intentional rabbit holes are built into the environment. Each is designed to be believable enough that a participant may reasonably spend time investigating it, which reinforces the value of careful verification over assumption. None of the three provides an actual flag, grants unintended privileged access, or offers a shortcut past the intended path - each is a deliberate, safe dead end.

Category	Purpose
Decoy data location	Tests whether participants verify content rather than assuming any plausible-looking location is the correct one.

Decoy web element	Tests discipline against investigating superficially interesting but ultimately unproductive web content.
Decoy system artifact	Tests whether participants recognize the difference between something that looks exploitable and something that actually is.

Exact rabbit hole locations and content are documented separately for the engagement facilitator only, and are not included in this proposal.

9. Hint/Riddle System

Every major stage has an optional hint available on request from the facilitator. Hints are delivered as riddles rather than direct instructions, so that a participant who requests one still has to do the work of interpreting and applying it, rather than simply being handed the next step.

Illustrative example only (not an actual hint used in the exercise): "A door does not always keep its key hanging beside it."

10. Skills Tested

Category	Representative Skills
Reconnaissance	Network/service discovery, web enumeration
Web analysis	Crawler-control file review, content inspection, encoding recognition
Steganography	Hidden-data detection and extraction, wordlist-based passphrase recovery
Access & credentials	SSH usage (password and key-based), credential decoding
Linux enumeration	Filesystem and permissions analysis, artifact discovery, log/history review
Reverse engineering	Static analysis of a compiled utility using standard tooling
Privilege escalation	Recognizing and correctly using a deliberately constrained escalation path

11. Difficulty Progression

The exercise is calibrated to a medium-to-hard overall difficulty band, with each flag building on skills and context established by the one before it. Early stages are approachable to participants with foundational

offensive-security knowledge, while later stages require sustained investigation and the ability to combine multiple techniques.

Difficulty Progression

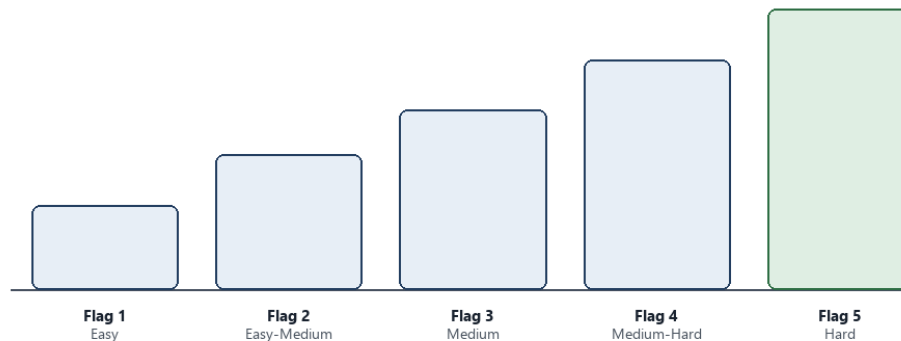


Figure 3: Relative difficulty by stage

12. Participant Experience

Participants are given only the CTF target's IP address and a short briefing covering the storyline, objective, flag format, ground rules, and how to request a hint. Everything else - services, entry points, accounts, and the path forward - is discovered through the participant's own work.

- No installation or setup is required on the participant side beyond a standard penetration-testing distribution (Kali Linux or Parrot Security).
- The exercise can be run individually or in teams, and can be reset between sessions to give every participant or team an identical starting state.
- The environment is non-destructive: participant actions are contained entirely within the isolated exercise network.
- Facilitators can pause the event to issue riddle-based hints without revealing solutions outright.

13. Security/Isolation Considerations

- The entire exercise runs inside a dedicated virtual environment with no route to the client's production systems, management interfaces, or other virtual machines.
- No real client credentials, keys, or data are used anywhere in the exercise - every credential, key, and flag is generated specifically for the exercise environment.
- The target and participant networks are logically separated from the underlying virtualization host and from each other's broader environment.
- The environment is fully resettable, so it can be safely reused across multiple sessions without any risk of state or credentials carrying over.
- No component of the exercise requires ongoing internet access once deployed.

14. Proposed Deliverables

Deliverable	Description
Configured CTF environment	A fully built and validated target system, ready to deploy within the client's Proxmox infrastructure.
Architecture & isolation guidance	Documentation covering the recommended network layout and isolation approach for the exercise.
Facilitator operations guide	A separate, organizer-only guide covering how to run, reset, and support the exercise during an event.
Participant briefing materials	A short, spoiler-free briefing document for distribution to participants at the start of the event.
Reset & re-use capability	The ability to reset the environment to a clean state between sessions, teams, or cohorts.

15. Attacker Machines

Kali/Parrot attacker machines will have tools like nmap, Burpsuite(CE), Metasploitable Framework, Wireshark, Browser, CTFd access and many other pen testing tools.

16. Supplementary Practice Environments

In addition to the core five-flag exercise, we can optionally provide a set of well-established, industry-standard vulnerable-by-design applications as separate, independent practice VMs. These are not part of the main storyline or attack path - they run as standalone, isolated machines alongside the core CTF target - and give participants a lower-pressure space to build and reinforce foundational skills before or in parallel with the main exercise.

Practice VM	Focus Area
OWASP Juice Shop	Modern web application vulnerabilities across the OWASP Top 10, including API security and business-logic flaws in a realistic e-commerce application.
DVWA (Damn Vulnerable Web Application)	Foundational, configurable-difficulty web application vulnerabilities - a strong on-ramp for participants newer to web security.
Metasploitable	Intentionally vulnerable Linux server for service enumeration, exploitation practice, and hands-on familiarity with the Metasploit framework.

Each practice VM is deployed and isolated the same way as the main CTF target, with no route between them or to production infrastructure. Because these are widely used, publicly available training platforms rather than custom-built environments, they add broad additional skill coverage - particularly classic web-application vulnerability classes - at minimal additional setup effort.

These practice VMs are entirely optional and are offered as a supplementary add-on. They do not affect the core five-flag storyline, its difficulty, or its flags in any way.

16. Conclusion

This exercise offers a realistic, engaging, and technically comprehensive way to exercise offensive-security skills in a controlled, safe, and fully isolated environment. Its progressive five-flag structure, believable storyline, and deliberately controlled privilege-escalation path make it suitable for skills development, team exercises, or assessment purposes, without introducing any risk to the client's production environment.

We welcome the opportunity to discuss scope, scheduling, and any customization the client would like to see reflected in the final exercise.